

Eng 4.9. Traverse

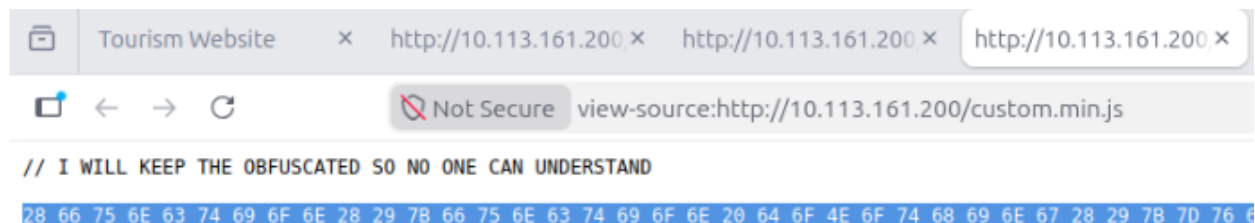
Traverse

Bob is a security engineer at a firm and works closely with the software/DevOps team to develop a tourism web application. Once the website was moved from QA to Production, the team noticed that the website was getting hacked daily and wanted to know the exact reason. Bob consulted the blue team as well but has yet to be successful. Therefore, he finally enrolled in the **Software Security** pathway at THM to learn if he was doing something wrong. Deploy the machine by clicking the **Start Lab Machine** button on the top right. You can access the website by visiting the URL `http://MACHINE_IP` via your VPN connection or the AttackBox.

Can you help Bob find the vulnerabilities and restore the website?

Answer the questions below

| What type of encoding is used by the hackers to obfuscate the JavaScript file?
hex (First, go to the page source and click the link provided in it.)



| What is the flag value after deobfuscating the file?

DIRECTORY LISTING IS THE ONLY WAY

Recipe

From Hex

Delimiter
Auto

Input

61 72 20 6E 3D 22 44 49 52 45 43 54 4F 52 59 22 38 76 61 72 20 65 3D 22 4C 49 53 54 49 4E 47 22 38 76 61
72 20 6F 3D 22 49 53 20 54 48 45 22 38 76 61 72 20 69 3D 22 4F 4E 4C 59 20 57 41 59 22 38 76 61 72 20 66
3D 6E 75 6C 6C 38 76 61 72 20 6C 3D 66 61 6C 73 65 38 76 61 72 20 64 38 69 66 28 66 3D 3D 6E 75 6C 6C
29 78 63 6F 6E 73 6F 6C 65 2E 6C 6F 67 28 22 46 6C 61 67 3A 22 28 6E 28 22 20 22 28 65 28 22 20 22 28 6F
28 22 20 22 28 69 29 38 64 3D 75 6E 64 65 66 69 6E 65 64 7D 65 6C 73 65 20 69 66 28 74 79 78 65 6F 66 20
66 3D 3D 3D 22 75 6E 64 65 66 69 6E 65 64 22 29 78 64 3D 75 6E 64 65 66 69 6E 65 64 7D 65 6C 73 65 78 69
66 28 6C 29 78 64 3D 75 6E 64 65 66 69 6E 65 64 7D 65 6C 73 65 78 28 66 75 6E 63 74 69 6F 6E 28 29 78 69
66 28 64 29 78 66 6F 72 28 76 61 72 20 6E 3D 30 38 6E 3C 31 30 38 6E 28 28 29 78 63 6F 6E 73 6F 6C 65 2E
6C 6F 67 28 22 54 68 69 73 20 63 6F 64 65 20 64 6F 65 73 20 6E 6F 74 68 69 6E 67 2E 22 29 7D 64 6F 4E 6F
74 68 69 6E 67 28 29 7D 65 6C 73 65 78 64 6F 4E 6F 74 68 69 6E 67 28 29 7D 29 28 29 7D 7D 29 28 29 38

Output

```

(function){function doNothing(){var n="DIRECTORY";var e="LISTING";var o="IS THE";var i="ONLY WAY";var
f=null;var l=false;var d;if(f===null){console.log("Flag:"+n "++" "++" "++");d=undefined}else if(typeof
f==="undefined"){d=undefined}else{if(l){d=undefined}else{(function){if(d){for(var n=0;n<10;n++){
console.log("This code does nothing.")doNothing()}else{doNothing()}}}}}}();

```

Logging is an important aspect. What is the name of the file containing email dumps?

email_dump.txt

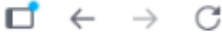
Tourism Website
x
http://10.113.161.200 x
http://10.113.161.200 x
http://10.113.161.200 x
cyberchef - Google x

Not Secure
view-source:http://10.113.161.200/

```

1 <!-- Rest PHP code and html content -->
2
3
4 <!DOCTYPE html>
5 <html lang="en">
6
7
8 <head>
9   <meta charset="UTF-8">
10  <meta name="viewport" content="width=device-width, initial-scale=1.0">
11  <title>Tourism Website</title>
12
13  <script src='/tailwind.min.js'></script> <!-- THIS IS OFFICIAL FILE - DO NOT CHANGE IT -->
14  <script src='custom.min.js'></script> <!-- THIS IS CUSTOM JS FILE-->
15  <link rel="stylesheet" href="/style.css">
16 </head>
17
18
19 <body>
20   <!-- Navigation Bar -->
21   <nav class="bg-gray-900 text-white p-6">
22     <div class="flex justify-between items-center">
23       <a href="/" class="text-lg font-bold">Tourism MHT </a>
24       <ul class="flex items-center gap-5">
25         <!-- <li><a href="/img" class="hover:text-gray-300">Logs</a></li> Please keep all images in this folder -->
26         <!-- <li><a href="/logs" class="hover:text-gray-300">Logs</a></li> DevOps team to check and remove it later on -->
27
28

```

 Not Secure http://10.113.161.200/logs/			
Index of /logs			
<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 email_dump.txt	2023-05-26 06:11	450	
<i>Apache/2.4.41 (Ubuntu) Server at 10.113.161.200 Port 80</i>			

The logs folder contains email logs and has a message for the software team lead. What is the name of the directory that Bob has created?

planning (aquasec.com SDLC)

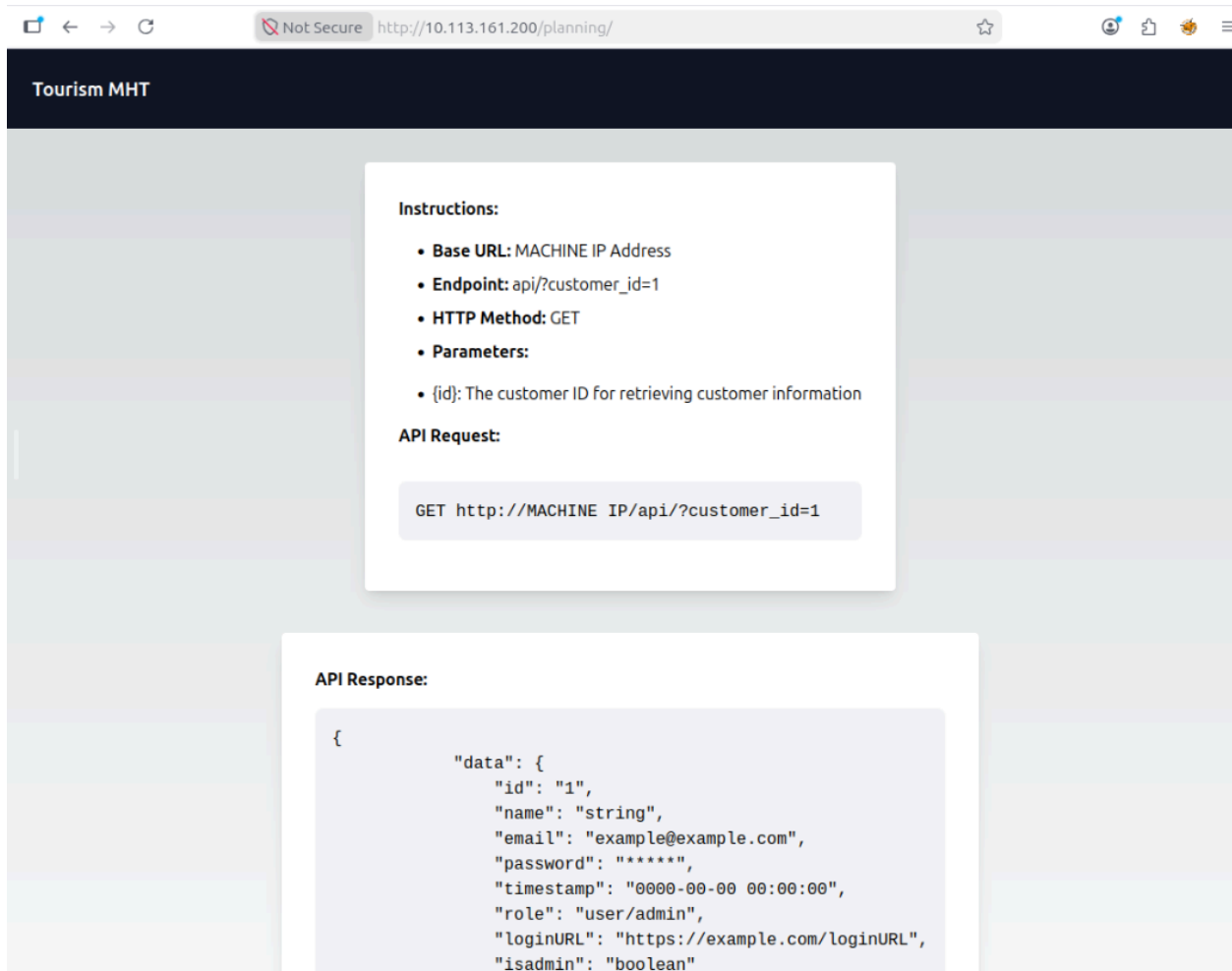
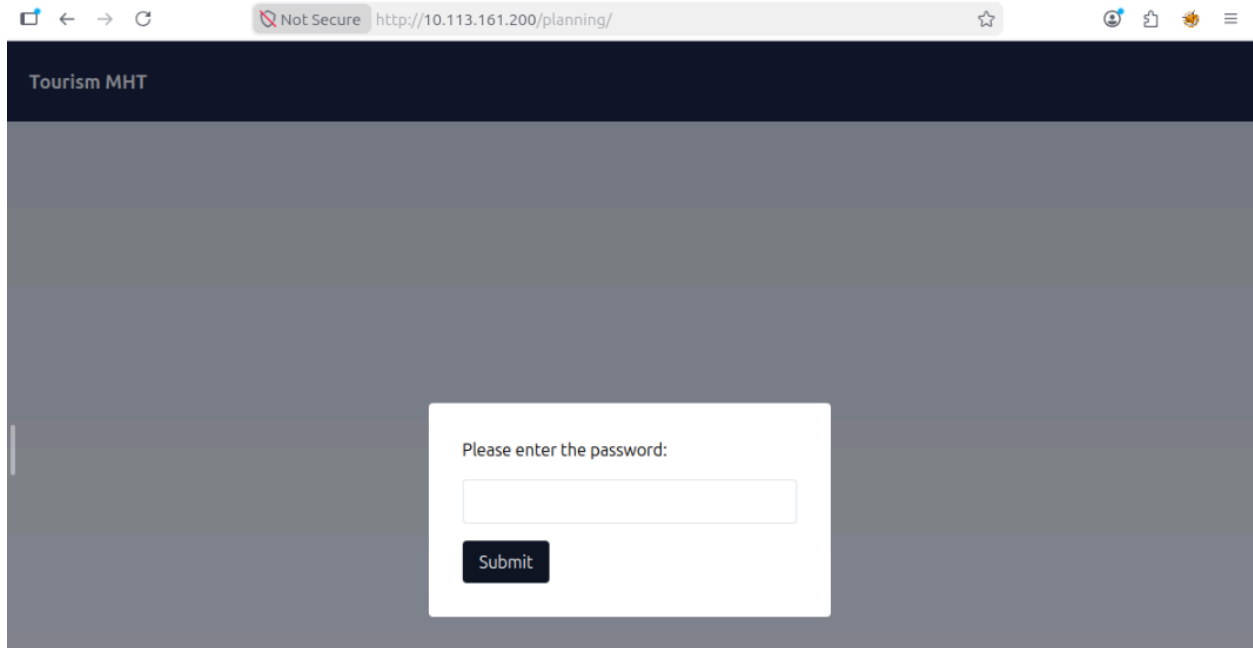
Embedding Security into All Phases of the SDLC

Ideally, you should secure each phase of the SDLC in the most appropriate manner for stakeholders present at that stage, while also ensuring that each security measure facilitates security practices across the whole project. Here are some key security practices to consider:

Planning

During the planning phase, stakeholders consider key aspects of the project and their alignment to the strategy for the final product. Examples of the topics considered at this phase include resource allocation, project scheduling, capacity planning, and provisioning.

At the end of this phase, you should have several outputs in hand, including cost estimations, procurement requirements, task schedules, and project plans. In a secure SDLC, considerations should be made for security, accounting for any additional requirements which could influence these deliverables. To ensure all perspectives are represented in the outputs of this phase, development teams and project managers should collaborate with stakeholders in security and operations.



What is the key file for opening the directory that Bob has created for Mark?

THM{100100111}



From: Bob <bob@tourism.mht>
To: Mark <mark@tourism.mht>
Subject: API Credentials

Hey Mark,

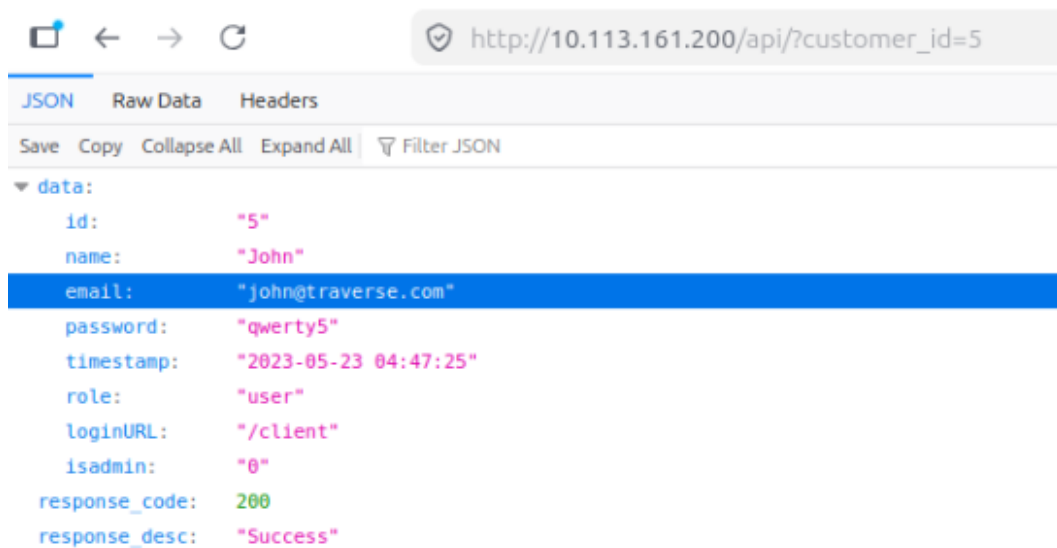
Sorry I had to rush earlier for the holidays, but I have created the directory for you with all the required information for the API. You loved SSDLC so much, I named the API folder under the name of the first phase of SSDLC. This page is password protected and can only be opened through the key. THM{100100111}

See ya after the holidays

Bob.

What is the email address for ID 5 using the leaked API endpoint?

john@traverse.com



http://10.113.161.200/api/?customer_id=5

JSON Raw Data Headers

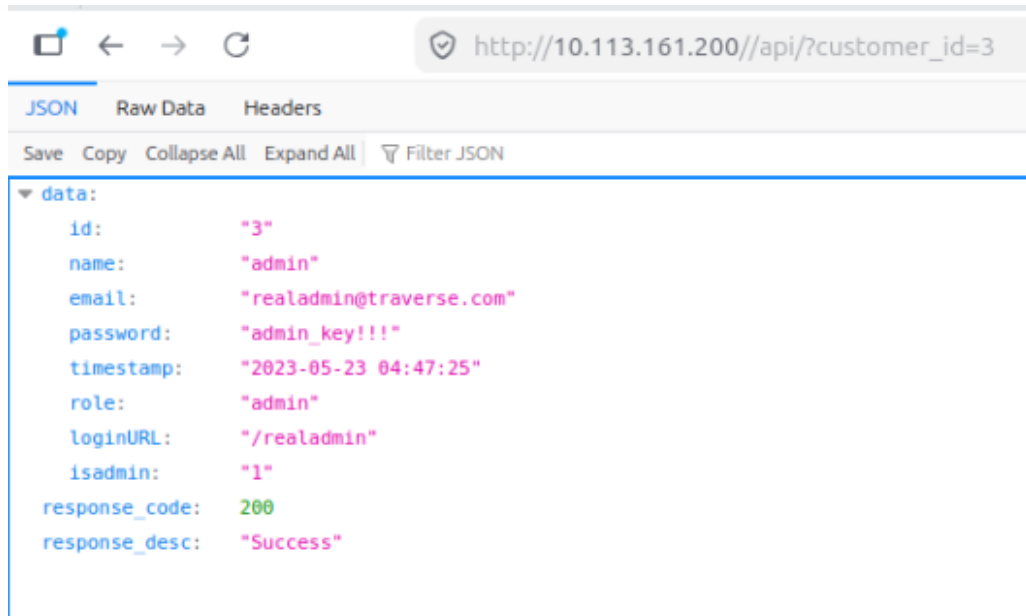
Save Copy Collapse All Expand All Filter JSON

data:

- id: "5"
- name: "John"
- email: "john@traverse.com"
- password: "qwerty5"
- timestamp: "2023-05-23 04:47:25"
- role: "user"
- loginURL: "/client"
- isadmin: "0"
- response_code: 200
- response_desc: "Success"

What is the ID for the user with admin privileges?

3

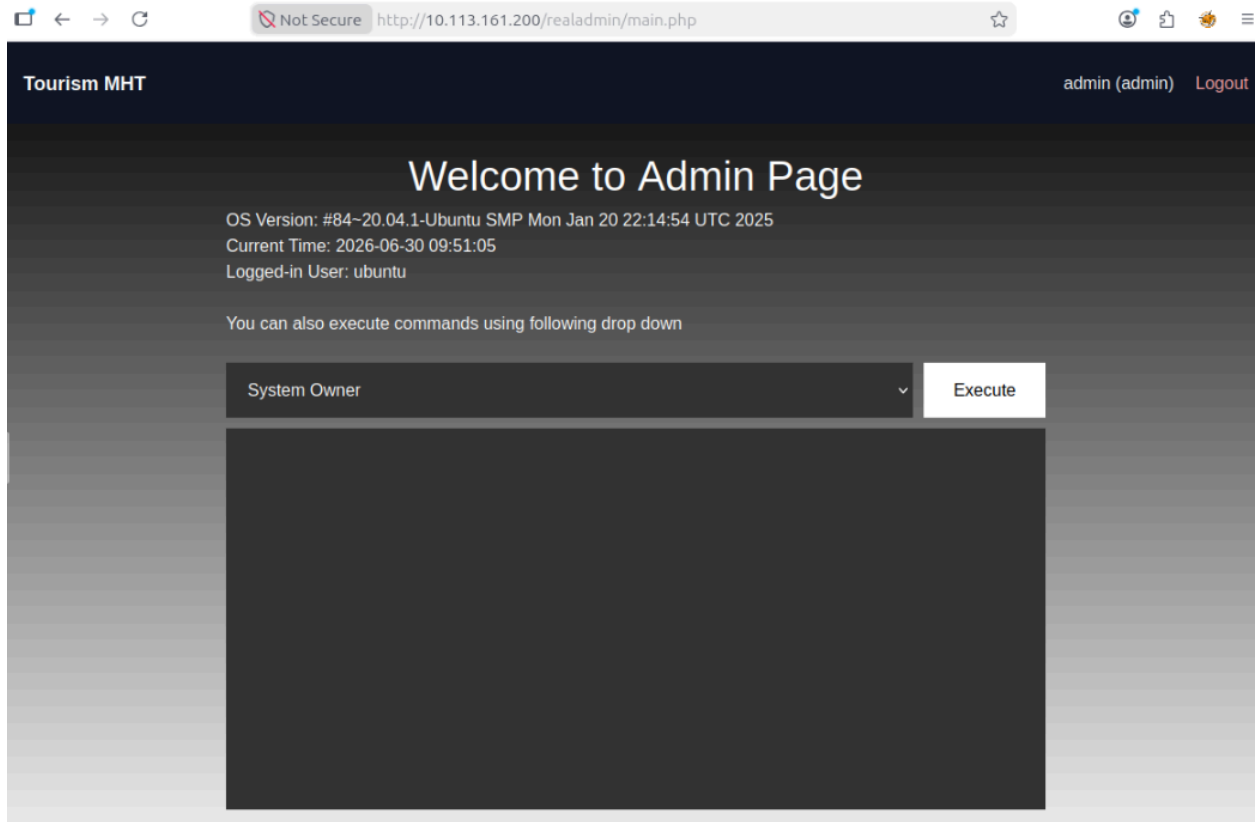


What is the endpoint for logging in as the **admin**?

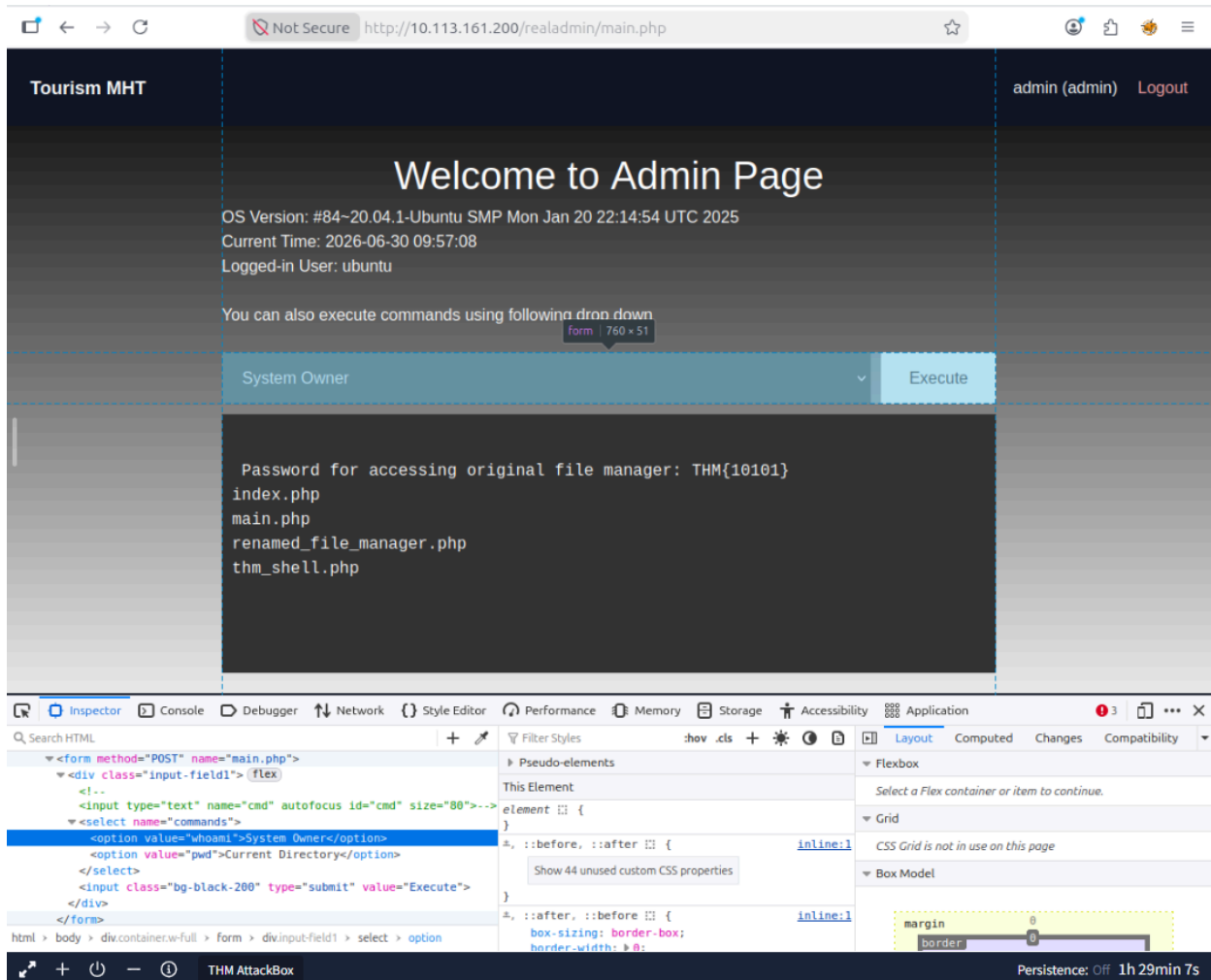
Mention the last endpoint instead of the URL. For example, if the answer is URL is tryhackme.com/admin - Just write **/admin**. realadmin

The attacker uploaded a web shell and renamed a file used for managing the server. Can you find the name of the web shell that the attacker has uploaded?

thm_shell.php



write ls in whoami then execute



What is the name of the file renamed by the attacker for managing the web server?

renamed_file_manager.php

Can you use the file manager to restore the original website by removing the **"FINALLY HACKED"** message? What is the flag value after restoring the main website?

10.113.161.200/api?custom
ADMIN FILE MANAGER
Passwords

Not Secure
http://10.113.161.200/realadmin/renamed_file_manager.php?p=

File Manager
Filter
Upload
New Item

You are logged in

☐	Name	Size	Modified	Perms	Owner	Actions
☐	api	Folder	05/26/2023 5:37 AM	0777	ubuntu:ubuntu	
☐	client	Folder	05/26/2023 5:37 AM	0777	ubuntu:ubuntu	
☐	img	Folder	05/26/2023 5:44 AM	0777	ubuntu:ubuntu	
☐	logs	Folder	05/26/2023 6:11 AM	0777	ubuntu:ubuntu	
☐	node_modules	Folder	06/02/2023 12:41 PM	0775	ubuntu:ubuntu	
☐	planning	Folder	05/26/2023 6:11 AM	0777	ubuntu:ubuntu	
☐	realadmin	Folder	05/26/2023 9:13 AM	0777	ubuntu:ubuntu	
☐	bitnami.css	177 B	06/15/2022 4:07 PM	0777	ubuntu:ubuntu	
☐	custom.min.js	1.19 KB	05/30/2023 9:00 AM	0777	ubuntu:ubuntu	
☐	footer.php	213 B	05/25/2023 2:26 PM	0777	ubuntu:ubuntu	
☐	header.php	1.66 KB	06/02/2023 12:57 PM	0777	ubuntu:ubuntu	
☐	index.php	732 B	06/02/2023 1:21 PM	0777	ubuntu:ubuntu	
☐	package.json	117 B	06/02/2023 11:57 AM	0664	ubuntu:ubuntu	
☐	style.css	377 B	06/02/2023 1:00 PM	0777	ubuntu:ubuntu	
☐	tailwind.min.js	348.16 KB	05/26/2023 6:05 AM	0777	ubuntu:ubuntu	

Full Size: 352.58 KB
File: 8
Folder: 7

☒ Select all
☐ Unselect all
☐ Invert Selection

My File Man

File Manager [index.php](#) Filter Upload New Item Admin

Back Back Up Advanced Editor Save

```
<!-- Rest PHP code and html content -->
<?php
include './api/login.php';
$basePath = "/";
?>

<!DOCTYPE html>
<html lang="en">

<?php
include 'header.php';
$message = "FINALLY HACKED";
?>

<!-- Main Content -->
<main class="mx-auto py-8 h-[80vh] flex items-center justify-center">

<div class="rounded overflow-hidden shadow-lg bg-white p-8 flex">
  <?php
  if($message != "NOT HACKED"){
    echo '<h1 class="text-gray-700 text-3xl py-6"> SUCCESSFULLY RESTORED WEBSITE FLAG: THM{WEBSITE_RESTORED}</h1>';
  }
  else{
    ?>
    <h2 class="text-gray-700 text-3xl py-6"> <?php echo $message; ?> !!! I HATE MINIFIED JAVASCRIPT</h2>
    <?php
    }
    ?>
  </div>

</main>

<?php
include 'footer.php';
```

